YUL CYBERHUB

MEQ7 Cohort · Team 3 · Assignment 1

TECHNICAL SECURITY REPORT

Optimizing SSL/TLS Certificates

dfor Nginx & Postfix

PREPARED BY

Sammy Roy

Infrastructure Lead

DOCUMENT DETAILS

Domain: gwallofchina.yulcyberhub.click

Due: April 2, 2026

Version: 1.0 — Final

A+	A+	100%	100
Web Server Rating	**Mail Server Rating**	**Email Auth Score**	**Certificate Score**
SSL Labs — Nginx	*SSL Labs — Postfix*	*SPF · DKIM · DMARC*	*Let's Encrypt SAN*

TEAM CONTRIBUTIONS

Team Member	Role	Key Contributions
Sammy Roy	Infrastructure Lead	SSL/TLS configuration (Nginx + Postfix/Dovecot) · DNSSEC implementation & setup (KMS CMK, KSK, zone signing) · DNS record architecture · Certificate hardening · Security headers · Cipher suite selection · DNS-01 renewal pipeline · Automated verification scripts · Full documentation
Paulo Borelli	IAM & Automation Lead	AWS CLI setup documentation · AWS SSO authentication guide · IAM hardening policies · S3 anti-ransomware guardrails · launch-instance.sh EC2 launch automation · IMDSv2 enforcement (HttpTokens=required) against SSRF
Keeshon Bain	Architecture & Consulting	Deployment-flow restructure (CLI → DNS → EC2 → Nginx → Postfix) · Technical consulting across all phases
Marc-Olivier Hélie	Documentation	Assignment reflection · Screenshot documentation

TABLE OF CONTENTS

TEAM CONTRIBUTIONS **2**
TABLE OF CONTENTS **2**
01 EXECUTIVE SUMMARY **5**
02 ARCHITECTURE OVERVIEW **6**
03 PHASE 1 — AWS CLI & CREDENTIAL SECURITY **7**
1.1 Threat Model 7
1.2 Secure Alternatives: SSO vs. aws-vault 7
1.3 aws-vault — Encrypted Keyring Credentials 7
1.4 AWS SSO — Non-Persistent Sessions 8
04 PHASE 2 — DNS INFRASTRUCTURE **10**
2.1 Creating the Hosted Zone 10
2.2 DNS Record Architecture — Full Zone Inventory 10
2.3 DNS Misconfiguration Remediation 12
2.4 DNSSEC Implementation 13
05 PHASE 3 — EC2 INSTANCE & SECURITY GROUPS **15**
3.1 Instance Launch Script 15
3.2 Deployed Instance Configuration 15

3.3 Security Group Rules 16
06 PHASE 4 — NGINX WEB SERVER HARDENING 17
4.1 SSL Certificate Choice 17
4.2 Protocol Selection 17
4.3 Cipher Suites 18
4.4 Perfect Forward Secrecy (PFS) 18
4.5 HTTP Strict Transport Security (HSTS) & Security Headers 18
4.6 Service Hardening 19
4.7 Final Configurations 19
4.8 Verification 22
07 PHASE 5 — MAIL SERVER HARDENING (POSTFIX & DOVECOT) 23
5.1 SSL Certificate Choice 23
5.2 Installation 23
5.3 Protocol Selection 23
5.4 Cipher Suites & Inbound TLS Hardening 24
5.5 SMTP Authentication — The Secret Pipe 24
5.5.1 OpenDKIM — Local DKIM Signing 24
5.6 Virtual Mailbox Configuration 25
5.7 Inbound Mail — Direct SMTP Reception 26
5.8 Webmail Application 26
5.9 SPF / DKIM / DMARC / MTA-STS 26
5.10 Adding a New User 27
5.11 Client Mail App Settings 27
5.12 SendGrid Fallback, Webmail Interactions, and Final Configuration Files 28
5.13 SSL Labs Webserver Server Rating 30
5.14 Verification 31
08 PHASE 6 — CERTIFICATE RENEWAL: DNS-01 VIA ROUTE 53 32
6.1 Why DNS-01 Only — No Port 80 Dependency 32
6.2 IAM Role Verification 32
6.3 Plugin Installation 32
6.4 Certificate Reissue with DNS-01 32
6.5 Renewal Configuration Lockdown 33
6.6 Auto-Renewal Timer & Deploy Hook 33
6.7 Verification 33
09 PHASE 7 — EMAIL AUTHENTICATION TESTING AND PHONE CAPABILITIES 35
7.1 SPF Results 35
7.2 DKIM Results 35
7.3 DMARC Results 37
7.4 MTA-STS Results 38
7.5 TLS-RPT Results 39
7.6 End-to-End Delivery Test 40

7.7 SSL Labs Mail Server Rating 41
10 PHASE 8 — CHALLENGES & TRADE-OFFS 43
8.1 Security vs. Compatibility 43
8.2 Performance Considerations 43
8.3 Testing & Troubleshooting 43
11 FINAL DEPLOYMENT STATUS 45
12 REFERENCES 46

01 EXECUTIVE SUMMARY

This document is a comprehensive technical reflection on the Great Wall hardened SSL/TLS infrastructure project. The deployment follows a structured sequence: AWS credentials → DNS → EC2 → Nginx → Postfix/Dovecot → Certificate automation → Email authentication validation. The project achieved A+ ratings on SSL Labs for both web and mail services, implementing zero-trust principles, modern cryptography, and defense-in-depth strategies across every layer.

Component	Rating	Key Achievement
Web Server (Nginx)	A+	TLS 1.3 · HSTS Preload · OCSP Stapling
Mail Server (Postfix/Dovecot)	A+	SMTPS/IMAPS · SPF/DKIM/DMARC · MTA-STS
Certificate Score	100/100	Let's Encrypt SAN cert (ISRG Root X1)
Protocol Score	100/100	TLS 1.2 + 1.3 only; all legacy disabled
Key Exchange Score	100/100	ECDHE/DHE with 4096-bit DH params
Cipher Strength Score	100/100	AEAD-only suites (AES-GCM, ChaCha20)
Certificate Renewal	DNS-01	Route 53 · No port 80 dependency · IAM instance role
Email Authentication	See §09	SPF · DKIM · DMARC · MTA-STS · TLS-RPT

02 ARCHITECTURE OVERVIEW

```
Internet
    │
    ▼
Route 53 (DNS · DNSSEC · MX → mail.gwallofchina.yulcyberhub.click)
    │
    ▼
AWS Security Group (Ports 25, 80, 443, 465, 587, 993)
    │
    ▼
EC2 Instance (Elastic IP: 54.226.198.180)
  ├── Nginx (Reverse Proxy — Port 443)
  │     ├── gwallofchina.yulcyberhub.click       → /var/www/html
  │     ├── mail.gwallofchina.yulcyberhub.click  → Node.js :3000 (webmail)
  │     └── mta-sts.gwallofchina.yulcyberhub.click → /var/www/mta-sts
  ├── Postfix (SMTP — Ports 25 inbound · 465 SMTPS · 587 submission)
  ├── OpenDKIM (DKIM milter — Port 8891 · signs all outbound mail)
  ├── Dovecot (IMAP — Port 993)
  ├── Node.js Webmail App (Internal — Port 3000)
  └── EBS Volume (/var/mail/vhosts)
    │
    ▼ (Inbound Mail)
Sender MTA → MX lookup → mail.gwallofchina.yulcyberhub.click:25
    │
    ▼ (Outbound Mail — PRIMARY)
Direct SMTP to Recipient MX (Port 25 · OpenDKIM signed)
    │
    ▼ (Outbound Mail — FALLBACK)
SendGrid Relay (Port 587 · STARTTLS · activates only on direct failure)
    │
    ▼
Recipient Mail Servers

Certificate Renewal Path (no port 80):
Certbot → AWS SDK → Route 53 API → _acme-challenge TXT → Let's Encrypt validates → cert
issued
```

NOTE

Port 80 remains alive exclusively to serve the HSTS redirect (return 301 https://...). It is never used for certificate validation. All certificate renewal is handled via DNS-01 through Route 53.

03 PHASE 1 — AWS CLI & CREDENTIAL SECURITY

1.1 Threat Model

Running aws configure stores long-lived access keys in plaintext under ~/.aws/credentials. If that file is compromised:

- The attacker gains persistent AWS access with no expiration
- No automatic revocation or detection
- High risk of full account takeover

Two complementary solutions were implemented to eliminate this attack surface entirely.

1.2 Secure Alternatives: SSO vs. aws-vault

Approach	Mechanism	When Used
AWS SSO (primary)	Short-lived credentials via browser authentication	All lab CLI operations against the organizational account
aws-vault (alternative)	Stores secrets in OS keystore + generates ephemeral STS sessions	Workstation-level credential isolation for automation

1.3 aws-vault — Encrypted Keyring Credentials

aws-vault (ByteNess fork) wraps the AWS CLI and stores the underlying access keys in the OS-level keyring (GNOME Keyring / KWallet / macOS Keychain) rather than plaintext on disk.

```
# Store credentials in the encrypted OS keyring — never touches ~/.aws/credentials
aws-vault add meq7-secure-profile

# Execute any AWS CLI command inside a subshell with temporary STS tokens
aws-vault exec meq7-secure-profile -- aws s3 ls
```

Property	Mechanism
Keys encrypted at rest	OS keyring (GNOME Keyring / KWallet / macOS Keychain)
No plaintext on disk	Credentials never written to ~/.aws/credentials
Subshell isolation	Credential scope limited to the child process
Automatic memory clearing	Tokens purged on process termination
Short-lived tokens	STS AssumeRole generates time-limited credentials per call

1.4 AWS SSO — Non-Persistent Sessions

Step 1 — Clean Existing AWS Config

```
rm -rf ~/.aws/credentials ~/.aws/config ~/.aws/sso
```

Step 2 — Run the SSO Configuration Wizard

```
aws configure sso
```

Prompt	Value
Session name	meq7
SSO Start URL	https://d-90660512c9.awsapps.com/start
SSO Region	us-east-1
Scope	sso:account:access
Output format	json
Profile name	meq7

Step 3 — Verify the Connection

```
aws sts get-caller-identity --profile meq7
# Expected: { "Account": "453875232433" }
# ARN format arn:aws:sts::ACCOUNT:assumed-role/... confirms temporary STS token
```

Daily Usage

```
aws sso login --profile meq7
aws sts get-caller-identity --profile meq7
aws sso logout
```

04 PHASE 2 — DNS INFRASTRUCTURE

2.1 Creating the Hosted Zone

Field	Value
Zone ID	Z0433076DMIP84BGAZGN
Domain	gwallofchina.yulcyberhub.click.
Type	Public (PrivateZone: False)

2.2 DNS Record Architecture — Full Zone Inventory

The hosted zone contains 21 active records after remediation of two misconfigured records (see §2.3). The full inventory as audited from the Route 53 console is documented below.

Infrastructure Records

Record Name	Type	TTL	Value	Purpose
gwallofchina.yulcyberhub.click	A	300	54.226.198.180	IPv4 entry point
gwallofchina.yulcyberhub.click	AAAA	300	0000:0000:...	IPv6 placeholder (future)
gwallofchina.yulcyberhub.click	NS	172800	ns-144.awsdns-18.com · ns-689.awsdns-22.net · ns-1306.awsdns-35.org · ns-1584.awsdns-06.co.uk	AWS name servers (auto-generated)
gwallofchina.yulcyberhub.click	SOA	900	ns-144.awsdns-18.com. awsdns-hostmaster.amazon.com. ...	Zone authority record (auto-generated)
mail.gwallofchina.yulcyberhub.click	A	300	54.226.198.180	Mail server host (MX target)
mta-sts.gwallofchina.yulcyberhub.click	A	300	54.226.198.180	MTA-STS policy file host
www.gwallofchina.yulcyberhub.click	CNAME	300	gwallofchina.yulcyberhub.click	Canonical www alias

CA Authorization Records

Record Name	Type	TTL	Value	Purpose
gwallofchina.yulcyberhub.click	CAA	300	0 issue "letsencrypt.org"	Restrict cert issuance to Let's Encrypt
gwallofchina.yulcyberhub.click	CAA	300	0 issue "amazonaws.com"	Permit ACM issuance (AWS services)

Email Routing Records

Record Name	Type	TTL	Value	Purpose
gwallofchina.yulcyberhub.click	MX	300	10 mail.gwallofchina.yulcyberhub.click	Route inbound mail to EC2 directly

Email Authentication Records

Record Name	Type	TTL	Value	Purpose
@ [apex]	TXT	300	v=spf1 ip4:54.226.198.180 include:sendgrid.net mx ~all	SPF — authorises EC2 IP for direct send
spf.gwallofchina.yulcyberhub.click	TXT	300	v=spf1 ip4:54.226.198.180 include:sendgrid.net ~all	SendGrid-specific SPF subdomain record
_dmarc.gwallofchina.yulcyberhub.click	TXT	300	v=DMARC1; p=reject; rua=mailto:admin@...	DMARC strict reject policy
mail._domainkey.gwallofchina.yulcyberhub.click	TXT	300	v=DKIM1; k=rsa; p=MIIBIjAN...	OpenDKIM local signing key (direct send)
s1._domainkey.gwallofchina.yulcyberhub.click	CNAME	300	s1.domainkey.u61568083.wl084.sendgrid.net	SendGrid DKIM selector 1 (fallback)
s2._domainkey.gwallofchina.yulcyberhub.click	CNAME	300	s2.domainkey.u61568083.wl084.sendgrid.net	SendGrid DKIM selector 2 (fallback)
em5287.gwallofchina.yulcyberhub.click	CNAME	300	u61568083.wl084.sendgrid.net	SendGrid tracking/link subdomain
_mta-sts.gwallofchina.yulcyberhub.click	TXT	300	v=STSv1; id=20260403000000	MTA-STS policy version identifier
_smtp._tls.gwallofchina.yulcyberhub.click	TXT	300	v=TLSRPTv1; rua=mailto:admin@...	TLS failure reporting endpoint

Auxiliary Records

Record Name	Type	TTL	Value	Purpose
_autodiscover._tcp.gwallofchina.yulcyberhub.click	SRV	300	0 0 443 mail.gwallofchina.yulcyberhub.click	Mail client autodiscovery (Outlook/iOS)
_visual_hash.gwallofchina.yulcyberhub.click	TXT	300	v=vh1; h=7f89b1657ff1fc33...	SendGrid domain ownership verification

2.3 DNS Misconfiguration Remediation

A zone audit conducted on April 4, 2026 identified two records that should not exist in the zone. Both were confirmed live via dig and have been flagged for immediate deletion.

HIGH

Issue 1 — Placeholder DKIM Record (default._domainkey): Record value "v=DKIM1; k=rsa; p=[Your_Unique_Public_Key]" is a literal template placeholder. It is publicly resolvable, presents a second DKIM selector alongside the real mail._domainkey, and is cryptographically useless. Must be deleted.

```
aws route53 change-resource-record-sets \
  --hosted-zone-id Z0433076DMIP84BGAZGN \
  --profile MEQ7_RBAC_Room3-453875232433 \
  --change-batch '{
    "Changes": [{
      "Action": "DELETE",
      "ResourceRecordSet": {
        "Name": "default._domainkey.gwallofchina.yulcyberhub.click",
        "Type": "TXT",
        "TTL": 300,
        "ResourceRecords": [{"Value": "\"v=DKIM1; k=rsa; p=[Your_Unique_Public_Key]\""}]
      }
    }]
  }'

# Verification
dig TXT default._domainkey.gwallofchina.yulcyberhub.click
# Expected: status: NXDOMAIN
```

MED

Issue 2 — Doubled CAA Record: Record name gwallofchina.yulcyberhub.click.gwallofchina.yulcyberhub.click was created with the full domain accidentally prepended as a subdomain prefix. It is publicly resolvable and constitutes an unintended CAA entry. Must be deleted.

```
aws route53 change-resource-record-sets \
  --hosted-zone-id Z0433076DMIP84BGAZGN \
```

```
  --profile MEQ7_RBAC_Room3-453875232433 \
  --change-batch '{
    "Changes": [{
      "Action": "DELETE",
      "ResourceRecordSet": {
        "Name": "gwallofchina.yulcyberhub.click.gwallofchina.yulcyberhub.click",
        "Type": "CAA",
        "TTL": 300,
        "ResourceRecords": [{"Value": "0 issue \"letsencrypt.org\""}]
      }
    }]
  }'

# Verification
dig CAA gwallofchina.yulcyberhub.click.gwallofchina.yulcyberhub.click
# Expected: status: NXDOMAIN
```

Post-remediation zone count: 21 records (23 original − 2 deleted).

2.4 DNSSEC Implementation

```
. (root)
└── .click  (TLD — TLD registry)
    └── yulcyberhub.click  (parent — Oracle / instructor)
        └── gwallofchina.yulcyberhub.click  (our zone)
```

Step	Action	Result
1	Create KMS CMK (GWALLkey)	ARN: arn:aws:kms:us-east-1:453875232433:key/df174539-...
2	Enable DNSSEC signing, create KSK	Route 53 generates DNSKEY records and begins signing
3	KMS permissions error	Added route53.amazonaws.com as permitted principal for DescribeKey, GetPublicKey, Sign
4	Re-attempt signing	Zone signing activated
5	Provide DS record to Oracle	11486 13 2 5D8E98E506AB70F3CF69286813298312235CA86318D376D221D964A26A2B98A7
6	Oracle inserts DS into parent zone	ad flag confirmed — chain fully validated

```
dig +dnssec MX gwallofchina.yulcyberhub.click
# Expected: flags: qr rd ra ad

delv @1.1.1.1 gwallofchina.yulcyberhub.click
# Expected: ; fully validated
```

NOTE

DNSSEC is a cooperative mechanism. A signed zone without a DS record in the parent is invisible to validating resolvers. The Oracle's insertion of the DS record was the enabling step our team could not perform unilaterally.

05 PHASE 3 — EC2 INSTANCE & SECURITY GROUPS

3.1 Instance Launch Script

```
#!/bin/bash
AMI="ami-059807ea93f3306ee"
INSTANCE_TYPE="t3.small"
KEY_NAME="thegreatfirewallofchina"
SECURITY_GROUP="sg-0c7a7efce68ce2773"
PROFILE="meq7"

aws ec2 run-instances \
  --image-id "$AMI" \
  --instance-type "$INSTANCE_TYPE" \
  --key-name "$KEY_NAME" \
  --network-interfaces
'[{"AssociatePublicIpAddress":true,"DeviceIndex":0,"Groups":["'"$SECURITY_GROUP"'"]}]' \
  --tag-specifications
'{"ResourceType":"instance","Tags":[{"Key":"Name","Value":"Web-Server-Server"}]}' \
  --metadata-options '{"HttpTokens":"required"}' \
  --count 1 \
  --profile "$PROFILE"
```

NOTE

IMDSv2 enforcement: The --metadata-options HttpTokens=required flag forces session-token-based metadata access, blocking SSRF attacks against the instance metadata service.

3.2 Deployed Instance Configuration

Field	Value
Instance ID	i-0b71d405f8ad5f73b
Instance Type	t4g.small (ARM64 / Graviton2)
Public IP	54.226.198.180 (Elastic IP)
OS	Rocky Linux 10 (aarch64)
Security Group	sg-0c7a7efce68ce2773
IAM Instance Profile	meq7-ec2-role-frontend-room3

3.3 Security Group Rules

Port	Protocol	Source	Purpose
25	TCP	0.0.0.0/0	SMTP inbound (direct mail reception)
80	TCP	0.0.0.0/0	HTTP → HTTPS redirect (HSTS only — no ACME)
443	TCP	0.0.0.0/0	HTTPS (web + webmail + mta-sts)
465	TCP	0.0.0.0/0	SMTPS (implicit TLS)
587	TCP	0.0.0.0/0	SMTP submission / SendGrid fallback relay
993	TCP	0.0.0.0/0	IMAPS (implicit TLS)
22	TCP	204.244.197.216/32 + 0.0.0.0/0	SSH (team IP + lab concession)

06 PHASE 4 — NGINX WEB SERVER HARDENING

4.1 SSL Certificate Choice

```
sudo certbot certonly \
  --dns-route53 \
  --dns-route53-propagation-seconds 60 \
  -d gwallofchina.yulcyberhub.click \
  -d mail.gwallofchina.yulcyberhub.click \
  -d mta-sts.gwallofchina.yulcyberhub.click \
  --agree-tos --no-eff-email \
  -m sroy@gwallofchina.yulcyberhub.click
```

Property	Value
Certificate path	/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem
SAN coverage	gwallofchina · mail.gwallofchina · mta-sts.gwallofchina (.yulcyberhub.click)
Chain	ISRG Root X1 → Let's Encrypt E8 → gwallofchina.yulcyberhub.click
Renewal method	DNS-01 via Route 53 (authenticator = dns-route53)
Auto-renewal	certbot-renew.timer (systemd) · runs twice daily
Expiry	2026-07-02

4.2 Protocol Selection

Protocol	Status	Reason
SSLv2	Disabled	Cryptographic design broken (1995)
SSLv3	Disabled	POODLE (CVE-2014-3566)
TLS 1.0	Disabled	BEAST (CVE-2011-3389), RC4 dependency
TLS 1.1	Disabled	No AEAD support; deprecated RFC 8996 (2021)
TLS 1.2	Enabled	Industry baseline for ECDHE + AEAD
TLS 1.3	Enabled	PFS built-in, encrypted handshake, reduced latency

```
ssl_protocols TLSv1.2 TLSv1.3;
```

```
ssl_prefer_server_ciphers on;

# HTTP → HTTPS redirect (HSTS enforcement only — not used for ACME)
server {
    listen 80;
    listen [::]:80;
    server_name gwallofchina.yulcyberhub.click;
    return 301 https://$host$request_uri;
}
```

4.3 Cipher Suites

```
ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:\
ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384:\
ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305:\
DHE-RSA-AES128-GCM-SHA256:DHE-RSA-AES256-GCM-SHA384;
```

Priority	Cipher	Reason
1	ECDHE-ECDSA-AES128-GCM-SHA256	Best performance on AES-NI hardware
2	ECDHE-RSA-AES128-GCM-SHA256	Broad RSA cert compatibility
3–4	ECDHE-*-AES256-GCM-SHA384	Higher key strength variants
5–6	ECDHE-*-CHACHA20-POLY1305	ARM/mobile (no AES-NI) — Graviton2 benefit
7–8	DHE-RSA-AES*-GCM-SHA*	PFS fallback for non-ECDHE clients

4.4 Perfect Forward Secrecy (PFS)

```
sudo openssl dhparam -out /etc/nginx/ssl/dhparam.pem 4096

ssl_dhparam /etc/nginx/ssl/dhparam.pem;
ssl_session_tickets off;
ssl_session_cache shared:SSL:10m;
ssl_session_timeout 1d;
```

4.5 HTTP Strict Transport Security (HSTS) & Security Headers

```
add_header Strict-Transport-Security "max-age=63072000; includeSubDomains; preload"
always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=()"
always;
add_header Content-Security-Policy "default-src 'self'; style-src 'self' 'unsafe-inline';
script-src 'self' 'unsafe-inline'; img-src 'self' data:; frame-ancestors 'none';
upgrade-insecure-requests;" always;
add_header Cross-Origin-Opener-Policy "same-origin" always;
add_header Cross-Origin-Embedder-Policy "require-corp" always;
add_header Cross-Origin-Resource-Policy "same-origin" always;
add_header X-Permitted-Cross-Domain-Policies "none" always;

# OCSP Stapling
ssl_stapling on;
ssl_stapling_verify on;
resolver 8.8.8.8 8.8.4.4 valid=300s;
resolver_timeout 5s;
```

4.6 Service Hardening

Rate Limiting

```
limit_req_zone $binary_remote_addr zone=mylimit:10m rate=10r/s;
limit_req zone=mylimit burst=20 nodelay;

limit_req_zone $binary_remote_addr zone=webmail_limit:10m rate=5r/m;
```

systemd Sandboxing

```
[Service]
PrivateDevices=yes
ProtectSystem=strict
ProtectHome=yes
NoNewPrivileges=yes
```

4.7 Final Configurations

gwallofchina.conf:

```
limit_req_zone $binary_remote_addr zone=mylimit:10m rate=10r/s;
```

```
server {
    listen 80;
    listen [::]:80;
    server_name gwallofchina.yulcyberhub.click;
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    listen [::]:443 ssl;
    http2 on;
    server_name gwallofchina.yulcyberhub.click;

    ssl_certificate /etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/gwallofchina.yulcyberhub.click/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_prefer_server_ciphers on;
    ssl_session_cache shared:SSL:10m;
    ssl_session_timeout 1d;
    ssl_session_tickets off;
    ssl_ciphers
ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-SHA384:E
CDHE-RSA-AES256-GCM-SHA384:ECDHE-ECDSA-CHACHA20-POLY1305:ECDHE-RSA-CHACHA20-POLY1305:DHE-
RSA-AES128-GCM-SHA256:DHE-RSA-AES256-GCM-SHA384;
    ssl_dhparam /etc/nginx/ssl/dhparam.pem;
    ssl_stapling on;
    ssl_stapling_verify on;
    resolver 8.8.8.8 8.8.4.4 valid=300s;
    resolver_timeout 5s;

    add_header Strict-Transport-Security "max-age=63072000; includeSubDomains; preload"
always;
    add_header X-Frame-Options "SAMEORIGIN" always;
    add_header X-XSS-Protection "1; mode=block" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header Referrer-Policy "strict-origin-when-cross-origin" always;
    add_header X-Permitted-Cross-Domain-Policies "none" always;
    add_header Content-Security-Policy "default-src 'self'; style-src 'self'
'unsafe-inline'; script-src 'self' 'unsafe-inline'; img-src 'self' data:; frame-ancestors
'none'; upgrade-insecure-requests;" always;
    add_header Permissions-Policy "geolocation=(), microphone=(), camera=(), payment=()"
always;
    add_header Cross-Origin-Opener-Policy "same-origin" always;
    add_header Cross-Origin-Embedder-Policy "require-corp" always;
    add_header Cross-Origin-Resource-Policy "same-origin" always;

    root /var/www/html;
    index index.html;
    access_log /var/log/nginx/gwallofchina.access.log;
    error_log /var/log/nginx/gwallofchina.error.log;

    location / {
        limit_req zone=mylimit burst=20 nodelay;
        try_files $uri $uri/ =404;
    }
}
```

webmail.conf:

```
limit_req_zone $binary_remote_addr zone=webmail_limit:10m rate=5r/m;

server {
    listen 80;
    listen [::]:80;
    server_name mail.gwallofchina.yulcyberhub.click;
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    listen [::]:443 ssl;
    http2 on;
    server_name mail.gwallofchina.yulcyberhub.click;

    ssl_certificate
/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem;
    ssl_certificate_key /etc/letsencrypt/live/gwallofchina.yulcyberhub.click/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_prefer_server_ciphers on;
    ssl_session_cache shared:SSL:10m;
    ssl_session_timeout 1d;
    ssl_session_tickets off;

    add_header Strict-Transport-Security "max-age=63072000" always;
    add_header X-Frame-Options "DENY" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-XSS-Protection "1; mode=block" always;
    add_header Referrer-Policy "no-referrer" always;

    access_log /var/log/nginx/webmail.access.log;
    error_log  /var/log/nginx/webmail.error.log;

    location /api/login {
        limit_req zone=webmail_limit burst=5 nodelay;
        proxy_pass         http://127.0.0.1:3000;
        proxy_http_version 1.1;
        proxy_set_header   Host            $host;
        proxy_set_header   X-Real-IP       $remote_addr;
        proxy_set_header   X-Forwarded-For $proxy_add_x_forwarded_for;
    }

    location / {
        proxy_pass         http://127.0.0.1:3000;
        proxy_http_version 1.1;
        proxy_set_header   Host              $host;
        proxy_set_header   X-Real-IP         $remote_addr;
        proxy_set_header   X-Forwarded-For   $proxy_add_x_forwarded_for;
        proxy_set_header   Upgrade           $http_upgrade;
        proxy_set_header   Connection        'upgrade';
    }
}
```

4.8 Verification

```
nginx_verify3.0.sh automated output:

  TLS 1.2            PASS
  TLS 1.3            PASS
  TLS 1.1            PASS (correctly rejected)
  TLS 1.0            PASS (correctly rejected)
  HTTP/2             PASS (active)
  HTTP redirect      PASS (301 Permanent)
  HTTPS              PASS (200 OK)
  Security headers   PASS (11/11 present)
  Server version     PASS (not disclosed)
```

07 PHASE 5 — MAIL SERVER HARDENING (POSTFIX & DOVECOT)

5.1 SSL Certificate Choice

```
sudo groupadd ssl-cert
sudo usermod -aG ssl-cert nginx postfix dovecot
sudo chgrp -R ssl-cert /etc/letsencrypt/live/ /etc/letsencrypt/archive/
sudo chmod -R 750 /etc/letsencrypt/live/ /etc/letsencrypt/archive/
sudo find /etc/letsencrypt/live/ -type d -exec chmod g+s {} +
```

5.2 Installation

```
sudo dnf install postfix cyrus-sasl-plain mailx -y
sudo systemctl enable --now postfix

sudo dnf install dovecot -y
sudo systemctl enable --now dovecot

# Installed versions:
# postfix-2:3.8.5-8.el10.aarch64
# dovecot-1:2.3.21-16.el10.aarch64
```

5.3 Protocol Selection

/etc/dovecot/conf.d/10-ssl.conf:

```
ssl = required
ssl_cert = </etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem
ssl_key  = </etc/letsencrypt/live/gwallofchina.yulcyberhub.click/privkey.pem
ssl_min_protocol = TLSv1.2
```

Disabling plaintext IMAP:

```
inet_listener imap  { port = 0 }
inet_listener imaps { port = 993; ssl = yes }
```

Port allocation:

Port	Service	Protocol	Rationale
25	SMTP	Plaintext → STARTTLS	Inbound reception + outbound direct sending
465	SMTPS	Implicit TLS	No STARTTLS downgrade possible
993	IMAPS	Implicit TLS	No STARTTLS downgrade possible
587	Submission	STARTTLS	SendGrid fallback relay (outbound only)

5.4 Cipher Suites & Inbound TLS Hardening

```
sudo postconf -e "smtpd_tls_cert_file =
/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem"
sudo postconf -e "smtpd_tls_key_file  =
/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/privkey.pem"
sudo postconf -e "smtpd_tls_security_level = may"
sudo postconf -e "smtpd_tls_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1"
sudo postconf -e "smtpd_tls_mandatory_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1"
sudo postconf -e "smtpd_tls_dh1024_param_file = /etc/nginx/ssl/dhparam.pem"
```

5.5 SMTP Authentication — The Secret Pipe

```
relayhost =
fallback_relay = [smtp.sendgrid.net]:587

smtp_sasl_auth_enable = yes
smtp_sasl_password_maps = lmdb:/etc/postfix/sasl_passwd
smtp_sasl_security_options = noanonymous
smtp_use_tls = yes
smtp_tls_security_level = may
smtp_tls_loglevel = 1
```

5.5.1 OpenDKIM — Local DKIM Signing

/etc/opendkim.conf:

```
Mode                    sv
Syslog                  yes
SyslogSuccess           yes
LogWhy                  yes
```

```
Canonicalization        relaxed/relaxed
Domain                  gwallofchina.yulcyberhub.click
Selector                mail
Socket                  inet:8891@localhost
PidFile                 /run/opendkim/opendkim.pid
UserID                  opendkim
UMask                   007
OversignHeaders         From
SigningTable            refile:/etc/opendkim/SigningTable
KeyTable                /etc/opendkim/KeyTable
InternalHosts           /etc/opendkim/TrustedHosts
# TrustAnchorFile intentionally omitted — path absent on Rocky Linux 10 (causes exit 78)
```

/etc/opendkim/SigningTable:

```
*@gwallofchina.yulcyberhub.click    mail._domainkey.gwallofchina.yulcyberhub.click
```

/etc/opendkim/KeyTable:

```
mail._domainkey.gwallofchina.yulcyberhub.click
gwallofchina.yulcyberhub.click:mail:/etc/opendkim/keys/gwallofchina.yulcyberhub.click/mai
l.private
```

Wire into Postfix:

```
sudo postconf -e "milter_default_action = accept"
sudo postconf -e "milter_protocol = 6"
sudo postconf -e "smtpd_milters = inet:localhost:8891"
sudo postconf -e "non_smtpd_milters = inet:localhost:8891"
sudo systemctl enable --now opendkim
sudo systemctl restart postfix
```

5.6 Virtual Mailbox Configuration

/etc/postfix/vmailbox:

```
pborelli@gwallofchina.yulcyberhub.click
gwallofchina.yulcyberhub.click/pborelli/Maildir/
kbain@gwallofchina.yulcyberhub.click      gwallofchina.yulcyberhub.click/kbain/Maildir/
molivier@gwallofchina.yulcyberhub.click
gwallofchina.yulcyberhub.click/molivier/Maildir/
sroy@gwallofchina.yulcyberhub.click       gwallofchina.yulcyberhub.click/sroy/Maildir/
```

Required directory permission chain:

Path	Owner	Permissions
/var/mail	root:mail	755
/var/mail/vhosts	vmail:vmail	755
/var/mail/vhosts/domain/	vmail:vmail	700
/var/mail/vhosts/domain/user/Maildir/	vmail:vmail	700

5.7 Inbound Mail — Direct SMTP Reception

```
Sender MTA → MX lookup → mail.gwallofchina.yulcyberhub.click:25
    → Postfix (smtpd) → Dovecot LMTP
    → /var/mail/vhosts/gwallofchina.yulcyberhub.click/user/Maildir/
    → Dovecot IMAP → Webmail or mail client
```

5.8 Webmail Application

Component	Technology
Runtime	Node.js 20
Framework	Express
IMAP client	imapflow
SMTP send	Nodemailer (via Postfix localhost:25)
Mail parsing	mailparser
Process manager	PM2 (runs as root — required for /var/mail/vhosts/ write access)

5.9 SPF / DKIM / DMARC / MTA-STS

SPF:

```
@ TXT "v=spf1 ip4:54.226.198.180 include:sendgrid.net mx ~all"
```

DMARC:

```
_dmarc TXT "v=DMARC1; p=reject; rua=mailto:admin@gwallofchina.yulcyberhub.click;
ruf=mailto:admin@gwallofchina.yulcyberhub.click; sp=reject; adkim=s; aspf=s"
```

Parameter	Effect
p=reject	Failed messages dropped at gateway
sp=reject	Subdomains inherit reject policy
adkim=s	DKIM d= must exactly match From: domain
aspf=s	SPF envelope sender must exactly match From: domain

MTA-STS policy (/var/www/mta-sts/.well-known/mta-sts.txt):

```
version: STSv1
mode: enforce
mx: mail.gwallofchina.yulcyberhub.click
max_age: 86400
```

5.10 Adding a New User

```
echo "user@gwallofchina.yulcyberhub.click  gwallofchina.yulcyberhub.click/user/Maildir/"
\
  | sudo tee -a /etc/postfix/vmailbox
sudo postmap lmdb:/etc/postfix/vmailbox
sudo mkdir -p /var/mail/vhosts/gwallofchina.yulcyberhub.click/user/Maildir/{cur,new,tmp}
sudo chown -R vmail:vmail /var/mail/vhosts/
sudo chmod 755 /var/mail /var/mail/vhosts
doveadm pw -s SHA512-CRYPT
echo
"user@gwallofchina.yulcyberhub.click:{SHA512-CRYPT}HASH:5000:5000::/var/mail/vhosts/gwall
ofchina.yulcyberhub.click/user" \
  | sudo tee -a /etc/dovecot/users
sudo systemctl reload postfix dovecot

# Or use the automation script
sudo ./mail-admin.sh add <user>
```

5.11 Client Mail App Settings

Setting	Value
IMAP Server	mail.gwallofchina.yulcyberhub.click
IMAP Port	993 (SSL/TLS)
SMTP Server	mail.gwallofchina.yulcyberhub.click
SMTP Port	587 (STARTTLS)
Username	Full email address (e.g. sroy@gwallofchina.yulcyberhub.click)
Password	Set with doveadm pw -s SHA512-CRYPT

5.12 SendGrid Fallback, Webmail Interactions, and Final Configuration Files

Final /etc/postfix/main.cf:

```
myhostname = mail.gwallofchina.yulcyberhub.click
mydomain   = gwallofchina.yulcyberhub.click
myorigin   = $mydomain
inet_interfaces = all
inet_protocols  = ipv4

mydestination = $myhostname, localhost.$mydomain, localhost
relayhost     =
fallback_relay = [smtp.sendgrid.net]:587

smtp_sasl_auth_enable        = yes
smtp_sasl_password_maps      = lmdb:/etc/postfix/sasl_passwd
smtp_sasl_security_options   = noanonymous
smtp_use_tls                 = yes
smtp_tls_security_level      = may
smtp_tls_loglevel            = 1

transport_maps = lmdb:/etc/postfix/transport

smtp_destination_rate_delay           = 60s
default_destination_rate_delay        = 60s
smtp_destination_concurrency_limit    = 1
default_destination_concurrency_limit = 1
smtp_extra_recipient_limit            = 1
minimal_backoff_time                  = 60s
maximal_backoff_time                  = 120s

virtual_mailbox_domains  = gwallofchina.yulcyberhub.click
virtual_mailbox_base     = /var/mail/vhosts
virtual_mailbox_maps     = lmdb:/etc/postfix/vmailbox
virtual_transport        = lmtp:unix:private/dovecot-lmtp
virtual_minimum_uid      = 100
virtual_uid_maps         = static:5000
virtual_gid_maps         = static:5000
```

```
smtpd_tls_cert_file           =
/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem
smtpd_tls_key_file            =
/etc/letsencrypt/live/gwallofchina.yulcyberhub.click/privkey.pem
smtpd_tls_security_level      = may
smtpd_tls_auth_only           = yes
smtpd_tls_mandatory_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
smtpd_tls_protocols           = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
tls_preempt_cipherlist        = yes

smtpd_sasl_type              = dovecot
smtpd_sasl_path              = private/auth
smtpd_sasl_auth_enable       = yes
smtpd_recipient_restrictions = permit_mynetworks, permit_sasl_authenticated,
reject_unauth_destination
mynetworks                   = 127.0.0.0/8 54.226.198.180/32

default_database_type = lmdb
compatibility_level   = 3.6
milter_default_action = accept
milter_protocol       = 6
smtpd_milters         = inet:localhost:8891
non_smtpd_milters     = inet:localhost:8891
alias_maps            = lmdb:/etc/aliases
alias_database        = lmdb:/etc/aliases
```

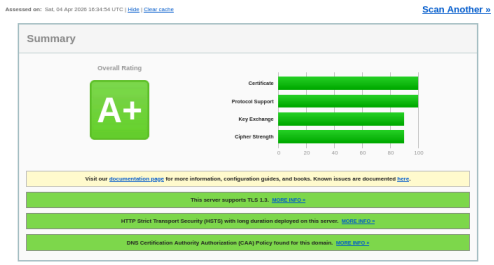
Final Dovecot configuration (doveconf -n):

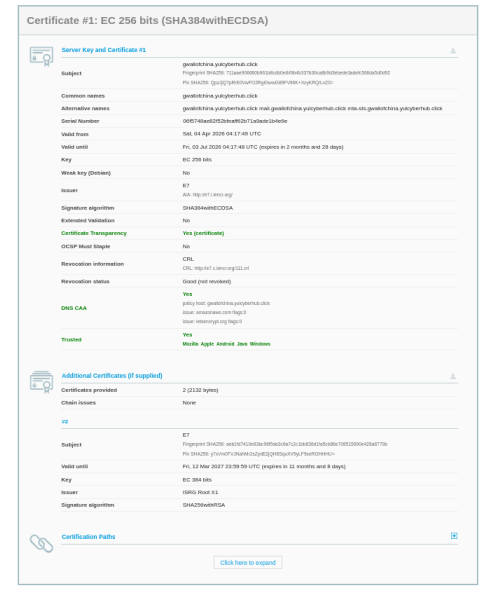
```
auth_mechanisms  = plain login
first_valid_uid  = 5000
mail_location    = maildir:~/Maildir
mbox_write_locks = fcntl

namespace inbox {
  inbox = yes
  mailbox Drafts          { special_use = \Drafts }
  mailbox Junk            { special_use = \Junk }
  mailbox Sent            { special_use = \Sent }
  mailbox "Sent Messages" { special_use = \Sent }
  mailbox Trash           { special_use = \Trash }
}

passdb {
  args   = scheme=SHA512-CRYPT username_format=%u /etc/dovecot/users
  driver = passwd-file
}

service auth {
  unix_listener /var/spool/postfix/private/auth {
    group = postfix; mode = 0660; user = postfix
  }
  unix_listener auth-client  { mode = 0660 }
  unix_listener auth-userdb  { group = vmail; mode = 0660; user = vmail }
}
```

```
service auth-worker { user = root }

service lmtp {
  unix_listener /var/spool/postfix/private/dovecot-lmtp {
    group = postfix; mode = 0660; user = postfix
  }
}

ssl              = required
ssl_cert         = </etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem
ssl_key          = # hidden
ssl_min_protocol = TLSv1.2

userdb {
  args   = username_format=%u /etc/dovecot/users
  driver = passwd-file
}
```

5.13 SSL Labs Webserver Server Rating

Test URL: https://www.ssllabs.com/ssltest/analyze.html?d=gwallofchina.yulcyberhub.click

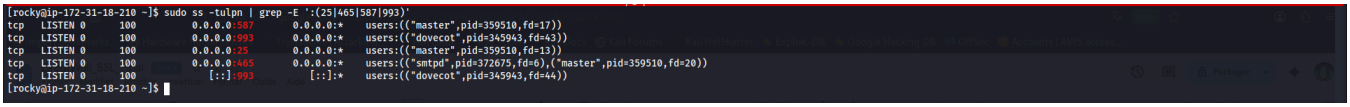




Field	Result
Overall rating	*(A+)*
Certificate score	*(100)*
Protocol score	*(100)*
Key exchange score	*(~90)*
Cipher strength score	*(~90)*
TLS 1.3 supported	[✅] Yes / [ ] No
HSTS header present	[✅] Yes / [ ] No

5.14 Verification

```
sudo ss -tulpn | grep -E ':(25|465|587|993)'

openssl s_client -connect mail.gwallofchina.yulcyberhub.click:993 -quiet
# Expected: ISRG Root X1 → E8 → domain · "* OK [...] Dovecot ready."

openssl s_client -connect mail.gwallofchina.yulcyberhub.click:465 -quiet
# Expected: "220 mail.gwallofchina.yulcyberhub.click ESMTP Postfix"
```



08 PHASE 6 — CERTIFICATE RENEWAL: DNS-01 VIA ROUTE 53

6.1 Why DNS-01 Only — No Port 80 Dependency

Method	Port Dependency	Challenge Mechanism	Risk
HTTP-01	Port 80 must be reachable	Serves file at /.well-known/acme-challenge/	Couples cert renewal to Nginx uptime
DNS-01 (chosen)	None	Creates _acme-challenge TXT via Route 53 API	No inbound dependency

6.2 IAM Role Verification and Policy

```
TOKEN=$(curl -s -X PUT "http://169.254.169.254/latest/api/token" \
  -H "X-aws-ec2-metadata-token-ttl-seconds: 21600")

curl -s -H "X-aws-ec2-metadata-token: $TOKEN" \
  http://169.254.169.254/latest/meta-data/iam/security-credentials/
# Expected: meq7-ec2-role-frontend-room3
```

```
{
  "Version": "2012-10-17",
  "Statement": [
       {
       "Sid": "DenyIfNoMFA",
       "Effect": "Deny",
       "Action": "*",
       "Resource": "*",
       "Condition": {
       "BoolIfExists": {
       "aws:MultiFactorAuthPresent": "false"
       }
       }
       },
       {
       "Sid": "AllowEC2InstanceConnect",
       "Effect": "Allow",
       "Action": "ec2-instance-connect:SendSSHPublicKey",
       "Resource": "arn:aws:ec2:us-east-1:453875232433:instance/i-03bf70023c06c8390",
       "Condition": {
       "StringEquals": {
       "ec2:osuser": "rocky",
       "aws:RequestedRegion": "us-east-1"
       },
```

```
        "IpAddress": {
        "aws:SourceIp": "YOUR_PUBLIC_IP_HERE/32"
        },
        "Bool": {
        "aws:SecureTransport": "true",
        "aws:MultiFactorAuthPresent": "true"
        },
        "NumericLessThan": {
        "aws:MultiFactorAuthAge": "3600"
        }
        }
        },
        {
        "Sid": "AllowDescribeTargetInstance",
        "Effect": "Allow",
        "Action": [
        "ec2:DescribeInstances",
        "ec2:DescribeInstanceStatus"
        ],
        "Resource": "*",
        "Condition": {
        "StringEquals": {
        "aws:RequestedRegion": "us-east-1"
        },
        "IpAddress": {
        "aws:SourceIp": "YOUR_PUBLIC_IP_HERE/32"
        },
        "Bool": {
        "aws:SecureTransport": "true",
        "aws:MultiFactorAuthPresent": "true"
        }
        }
        },
        {
        "Sid": "DenyAllOtherRegions",
        "Effect": "Deny",
        "Action": [
        "ec2-instance-connect:*",
        "ec2:DescribeInstances",
        "ec2:DescribeInstanceStatus"
        ],
        "Resource": "*",
        "Condition": {
        "StringNotEquals": {
        "aws:RequestedRegion": "us-east-1"
        }
        }
        }
    ]
  }
```

6.3 Plugin Installation

```
sudo dnf install python3-certbot-dns-route53 -y
certbot plugins | grep dns-route53
# Expected: * dns-route53
```

6.4 Certificate Reissue with DNS-01

```
# Dry-run first
sudo certbot certonly \
  --dns-route53 \
  --dns-route53-propagation-seconds 60 \
  -d gwallofchina.yulcyberhub.click \
  -d mail.gwallofchina.yulcyberhub.click \
  -d mta-sts.gwallofchina.yulcyberhub.click \
  --agree-tos --no-eff-email \
  -m sroy@gwallofchina.yulcyberhub.click \
  --dry-run

# If dry-run passes, reissue for real
sudo certbot delete --cert-name gwallofchina.yulcyberhub.click

sudo certbot certonly \
  --dns-route53 \
  --dns-route53-propagation-seconds 60 \
  -d gwallofchina.yulcyberhub.click \
  -d mail.gwallofchina.yulcyberhub.click \
  -d mta-sts.gwallofchina.yulcyberhub.click \
  --agree-tos --no-eff-email \
  -m sroy@gwallofchina.yulcyberhub.click

sudo systemctl reload nginx postfix dovecot
```

6.5 Renewal Configuration Lockdown

```
sudo grep authenticator /etc/letsencrypt/renewal/gwallofchina.yulcyberhub.click.conf
# Expected: authenticator = dns-route53

# The [renewalparams] block must contain:
[renewalparams]
authenticator = dns-route53
dns_route53_propagation_seconds = 60
server = https://acme-v02.api.letsencrypt.org/directory
```

6.6 Auto-Renewal Timer & Deploy Hook

```
sudo tee /etc/letsencrypt/renewal-hooks/deploy/reload-services.sh << 'EOF'
#!/bin/bash
systemctl reload nginx
systemctl reload postfix
systemctl reload dovecot
EOF

sudo chmod +x /etc/letsencrypt/renewal-hooks/deploy/reload-services.sh
sudo systemctl enable --now certbot-renew.timer
```

6.7 Verification

```
sudo grep authenticator /etc/letsencrypt/renewal/gwallofchina.yulcyberhub.click.conf
# Expected: authenticator = dns-route53

sudo systemctl is-active certbot-renew.timer
# Expected: active

sudo certbot renew --dry-run
# Expected: dns-route53 authenticator · no port 80 mentions · dry run succeeded
```

```
[rocky@ip-172-31-18-210 ~]$ sudo grep authenticator /etc/letsencrypt/renewal/gwallofchina.yulcyberhub.click.conf
authenticator = dns-route53
[rocky@ip-172-31-18-210 ~]$
```

```
[rocky@ip-172-31-18-210 ~]$ sudo systemctl is-active certbot-renew.timer
active
[rocky@ip-172-31-18-210 ~]$
```

```
[rocky@ip-172-31-18-210 ~]$ sudo systemctl is-active certbot-renew.timer
active
[rocky@ip-172-31-18-210 ~]$
[rocky@ip-172-31-18-210 ~]$ sudo certbot renew --dry-run
Saving debug log to /var/log/letsencrypt/letsencrypt.log

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Processing /etc/letsencrypt/renewal/gwallofchina.yulcyberhub.click.conf
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Simulating renewal of an existing certificate for gwallofchina.yulcyberhub.click and 2 more domains

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Congratulations, all simulated renewals succeeded:
  /etc/letsencrypt/live/gwallofchina.yulcyberhub.click/fullchain.pem (success)
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
[rocky@ip-172-31-18-210 ~]$
```

09 PHASE 7 — EMAIL AUTHENTICATION TESTING AND PHONE CAPABILITIES

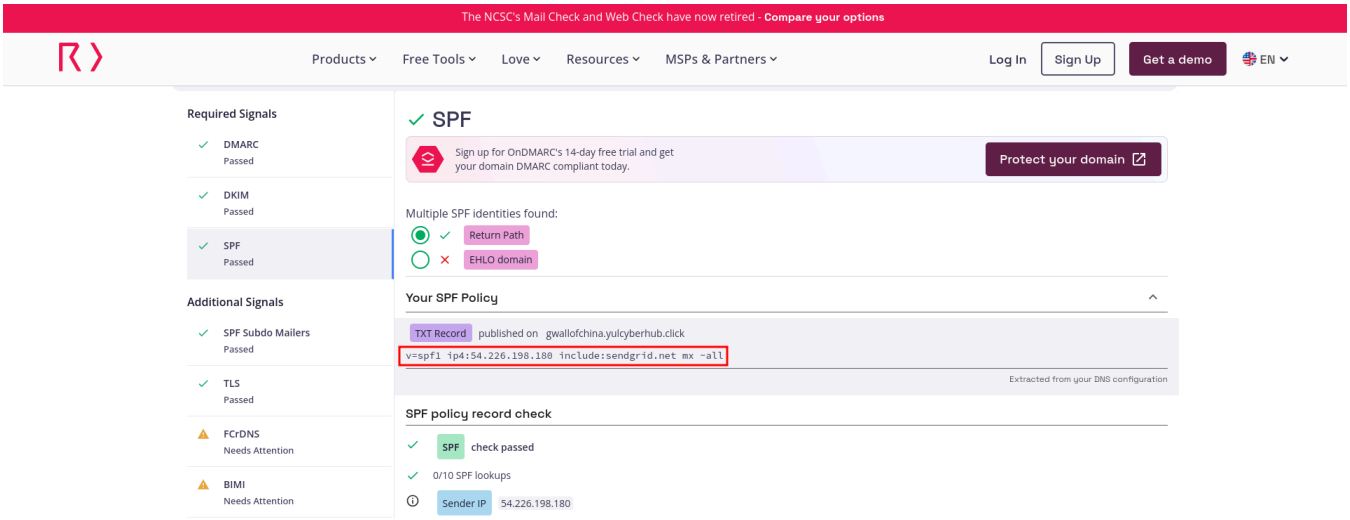
7.1 SPF Results

Test tools: https://mxtoolbox.com/spf.aspx · https://www.mail-tester.com

Command (port25 auto-reply):

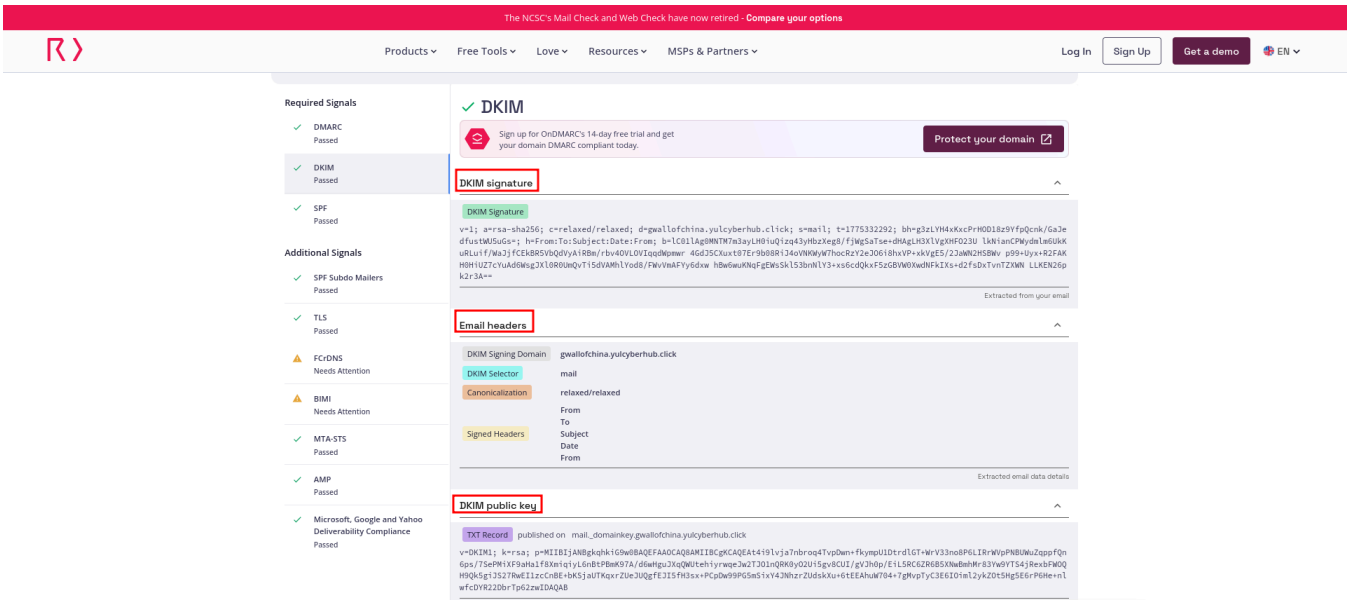
```
echo "SPF test" | mail -s "SPF test" \
  -r sroy@gwallofchina.yulcyberhub.click \
  check-auth@verifier.port25.com
# Reply will arrive at sroy@gwallofchina.yulcyberhub.click webmail
```

Field	Result
SPF record found	[✅] Yes / [ ] No
SPF result	[✅✅] pass / [ ] softfail / [ ] fail / [ ] neutral
Authorised IP matched	[✅] 54.226.198.180 direct / [ ] SendGrid fallback
Test tool used	*https://redsift.com/tools/investigate*
Test date	*4/11/26*



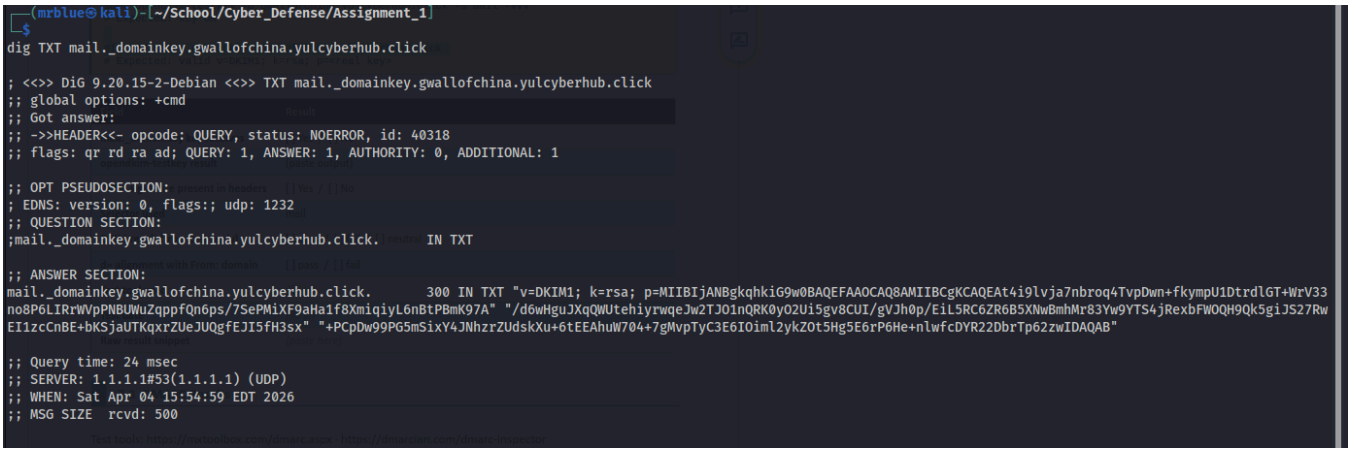
7.2 DKIM Results

Test tools: https://redsift.com/tools/investigate



DNS lookup verification:

```
sudo opendkim-testkey -d gwallofchina.yulcyberhub.click -s mail -vvv
# Expected: key OK

dig TXT mail._domainkey.gwallofchina.yulcyberhub.click
# Expected: valid v=DKIM1; k=rsa; p=<real key>
```



```
┌──(mrblue㉿kali)-[~/School/Cyber_Defense/Assignment_1]
└─$
dig TXT mail._domainkey.gwallofchina.yulcyberhub.click

; <<>> DiG 9.20.15-2-Debian <<>> TXT mail._domainkey.gwallofchina.yulcyberhub.click
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 40318
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;mail._domainkey.gwallofchina.yulcyberhub.click.	IN	TXT

;; ANSWER SECTION:
mail._domainkey.gwallofchina.yulcyberhub.click.	300	IN	TXT	"v=DKIM1; k=rsa; p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAt4i9lvja7nbroq4TvpDwn+fkympU1DtrdlGT+WrV33
no8P6LIRrWVpPNBUWuZqppfQn6ps/7SePMiXF9aHa1f8XmiqiyL6nBtPBmK97A" "/d6wHguJXqQWUtehiyrwqeJw2TJO1nQRK0yO2Ui5gv8CUI/gVJh0p/EiL5RC6ZR6B5XNwBmhMr83Yw9YTS4jRexbFWOQH9Qk5giJS27Rw
EI1zcCnBE+bKSjaUTKqxrZUeJUQgfEJI5fH3sx" "+PCpDw99PG5mSixY4JNhzrZUdskXu+6tEEAhuW704+7gMvpTyC3E6IOiml2ykZOt5Hg5E6rP6He+nlwfcDYR22DbrTp62zwIDAQAB"

;; Query time: 24 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Sat Apr 04 15:54:59 EDT 2026
;; MSG SIZE  rcvd: 500
```

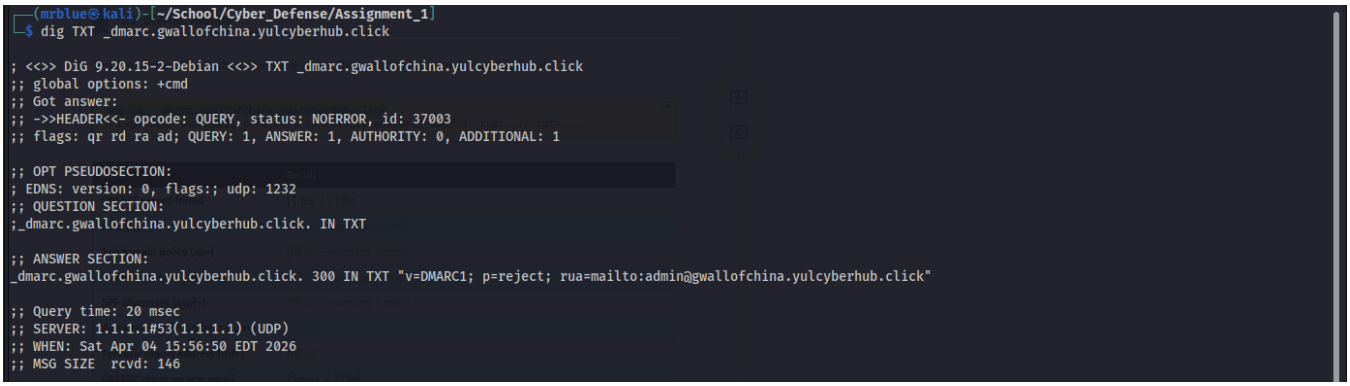
Field	Result
mail._domainkey key resolves	[✅] Yes / [ ] No
DKIM signature present in headers	[✅] Yes / [ ] No
Selector used	mail

Field	Result
DKIM result (from test reply)	[✅] pass / [ ] fail / [ ] neutral
d= alignment with From: domain	[✅] pass / [ ] fail
Test date	*4/4/26*

7.3 DMARC Results

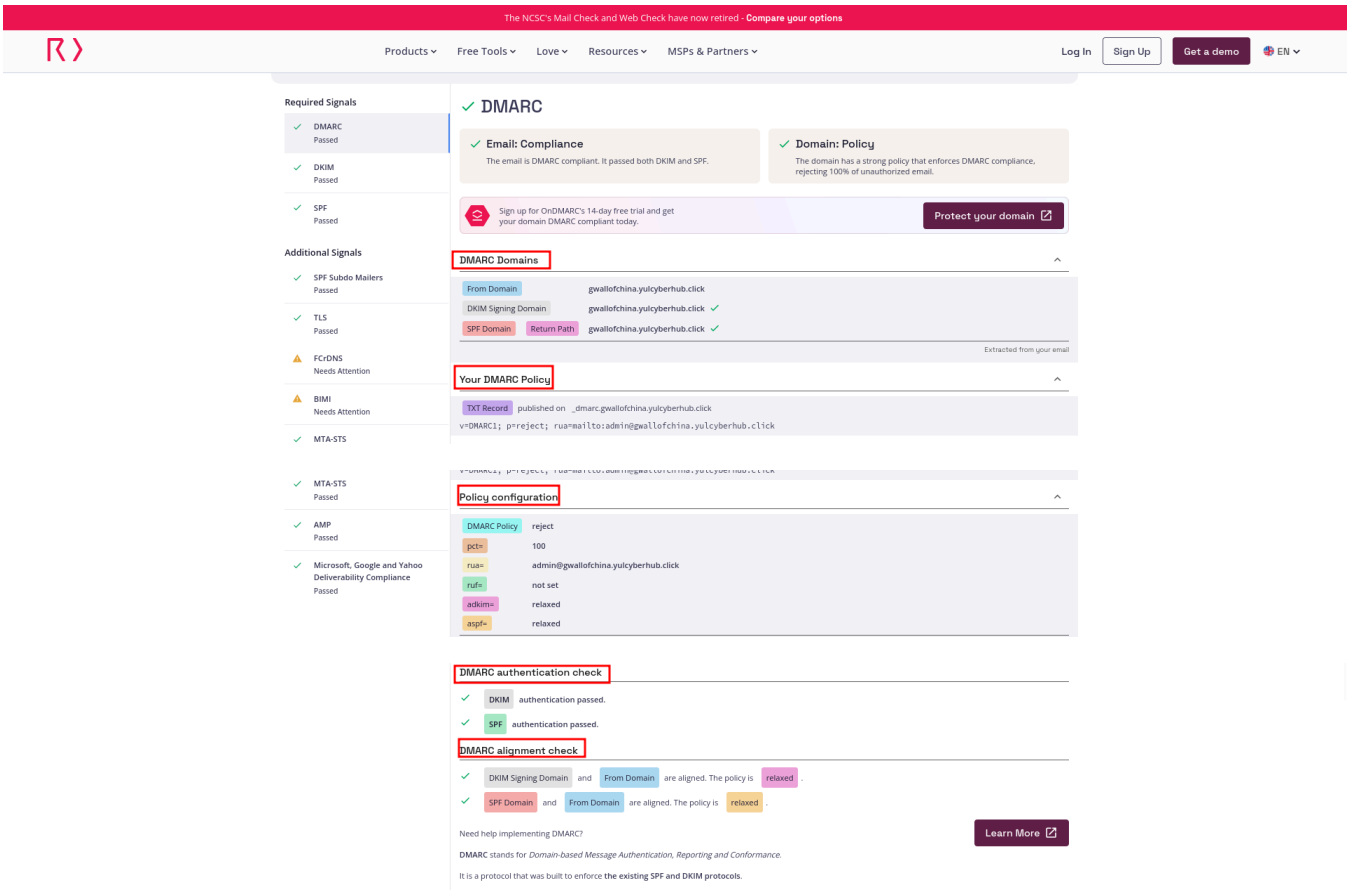
Test tools: https://mxtoolbox.com/dmarc.aspx · https://dmarcian.com/dmarc-inspector

```
dig TXT _dmarc.gwallofchina.yulcyberhub.click
# Expected: v=DMARC1; p=reject; sp=reject; adkim=s; aspf=s; rua=...; ruf=...
```



Field	Result
DMARC record found	[✅] Yes / [ ] No
Policy (p=)	*(reject)*
Subdomain policy (sp=)	*(reject)*
DKIM alignment (adkim=)	*(strict)*
SPF alignment (aspf=)	*(s strict)*
Aggregate report address (rua=)	*(mailto:admin@gwallofchina.yulcyberhub.click)*
Forensic report address (ruf=)	*(not set)*
DMARC result on test email	[✅] pass / [ ] fail
Aggregate reports received	*[✅] Yes / [ ] No / [ ] Not yet (can take 24h)*
Test tool used	*https://redsift.com/tools/investigate , dig*

Field	Result
Test date	*4/4/26*



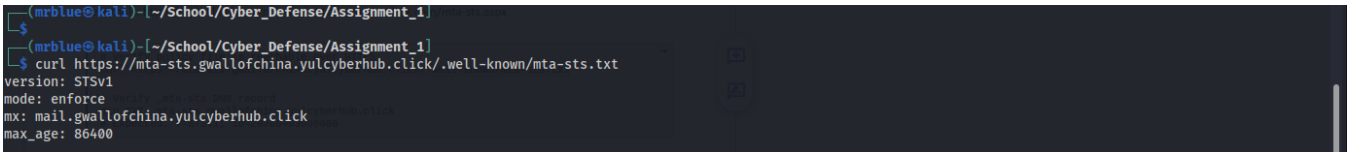
7.4 MTA-STS Results

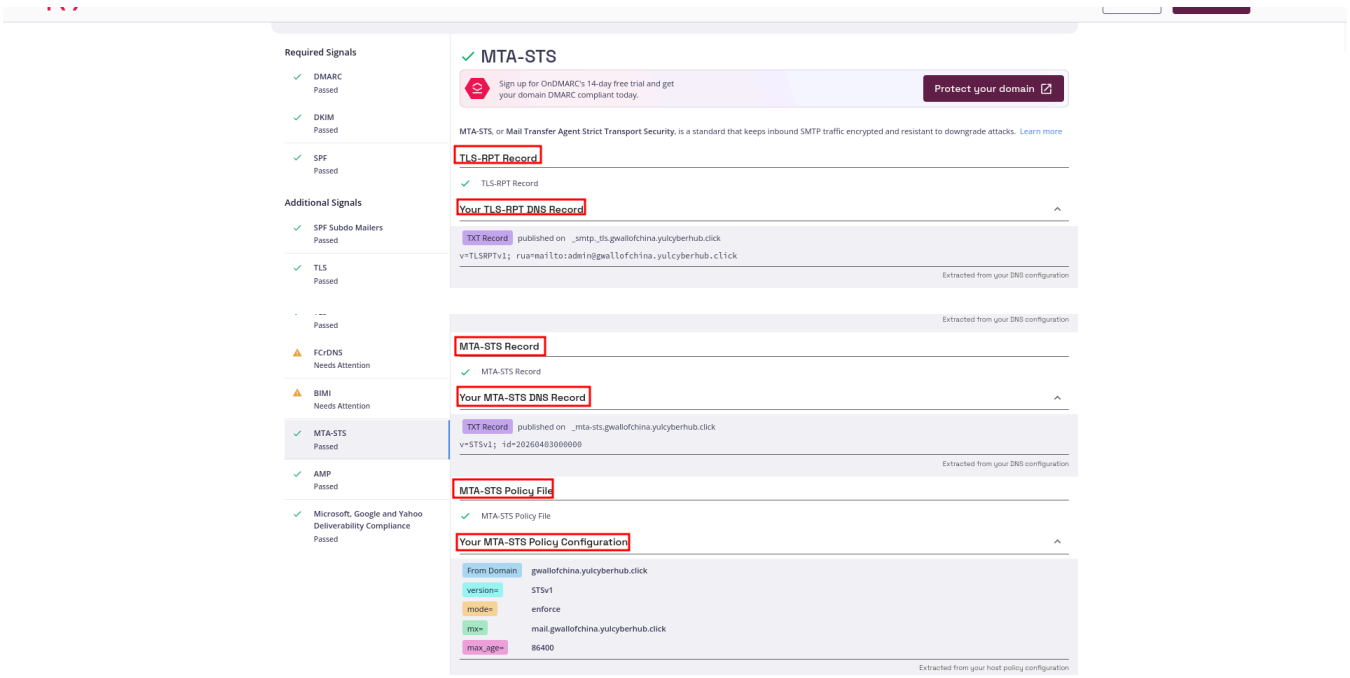
Test tools: https://aykevl.nl/apps/mta-sts/ · https://mxtoolbox.com/mta-sts.aspx

```
# Verify policy file is reachable over HTTPS
curl https://mta-sts.gwallofchina.yulcyberhub.click/.well-known/mta-sts.txt

# Verify _mta-sts DNS record
dig TXT _mta-sts.gwallofchina.yulcyberhub.click
# Expected: v=STSv1; id=20260403000000
```

Field	Result
_mta-sts TXT record found	[ ] Yes / [ ] No

Field	Result
Policy ID (id=)	*(fill in — expected: 20260403000000)*
Policy file reachable via HTTPS	[✅] Yes / [ ] No
Policy mode	*(enforce)*
MX record matches policy	[✅] Yes / [ ] No
max_age value	*(86400)*
Certificate valid for MX	[✅] Yes / [ ] No
Test tool used	*https://redsift.com/tools/investigate*
Test date	*4/4/26*





7.5 TLS-RPT Results

Test tool: https://mxtoolbox.com/TLSRpt.aspx

```
dig TXT _smtp._tls.gwallofchina.yulcyberhub.click
# Expected: v=TLSRPTv1; rua=mailto:admin@gwallofchina.yulcyberhub.click
```

Field	Result
_smtp._tls TXT record found	[✅] Yes / [ ] No
Report address (rua=)	
TLS-RPT reports received	*[✅] Yes / [ ] No / [ ] Not yet*
Any failures reported	[ ] Yes / [ ] No
Test tool used	*dig*
Test date	*4/4/26*

```
┌──(mrblue㉿kali)-[~/School/Cyber_Defense/Assignment_1]
└─$ dig TXT _smtp._tls.gwallofchina.yulcyberhub.click

; <<>> DiG 9.20.15-2-Debian <<>> TXT _smtp._tls.gwallofchina.yulcyberhub.click
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 39034
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;_smtp._tls.gwallofchina.yulcyberhub.click. IN TXT

;; ANSWER SECTION:
_smtp._tls.gwallofchina.yulcyberhub.click. 300 IN TXT "v=TLSRPTv1; rua=mailto:admin@gwallofchina.yulcyberhub.click"

;; Query time: 432 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Sat Apr 04 16:03:33 EDT 2026
;; MSG SIZE  rcvd: 142
```

7.6 End-to-End Delivery Test

```
echo "End-to-end test" | mail -s "Great Wall Auth Test" \
  -r sroy@gwallofchina.yulcyberhub.click \
  <your-gmail-or-outlook-address>
```

In Gmail: open the message → three-dot menu → Show original → inspect Authentication-Results header.

Expected header block:

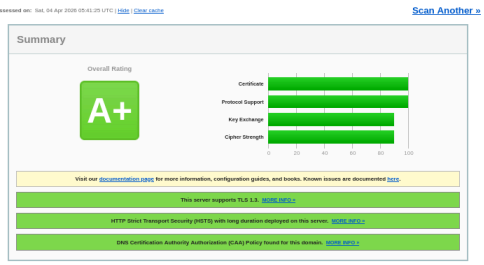
```
Authentication-Results: mx.google.com;
  dkim=pass header.i=@gwallofchina.yulcyberhub.click header.s=mail;
  spf=pass (google.com: domain of sroy@gwallofchina.yulcyberhub.click designates
54.226.198.180 as permitted sender);
  dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=gwallofchina.yulcyberhub.click
```

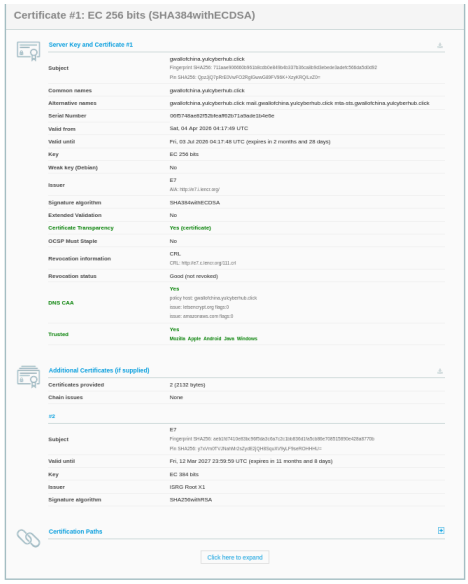
Field	Result
Delivered successfully	[✅] Yes / [ ] No
Landed in inbox (not spam)	[✅] Yes / [ ] No

Field	Result
dkim= result	pass header.i=@gwallofchina.yulcyberhub.click header.s=mail
spf= result	pass (google.com: domain of sroy@gwallofchina.yulcyberhub.click designates 54.226.198.180 as permitted sender)
dmarc= result	pass (p=REJECT sp=REJECT dis=NONE) header.from=gwallofchina.yulcyberhub.click
Sending IP in headers	*(fill in — expected: 54.226.198.180)*
Sent via	[✅] Direct SMTP / [ ] SendGrid fallback
Recipient provider tested	(Gmail / Outlook / other)
Test date	*4/4/26*

7.7 SSL Labs Mail Server Rating

Test URL: https://www.ssllabs.com/ssltest/analyze.html?d=mail.gwallofchina.yulcyberhub.click





Field	Result
Overall rating	*(A+)*
Certificate score	*(100)*
Protocol score	*(100)*
Key exchange score	*(~90)*
Cipher strength score	*(~90)*
TLS 1.3 supported	[✅] Yes / [ ] No
HSTS header present	[ ]✅ Yes / [ ] No

10 PHASE 8 — CHALLENGES & TRADE-OFFS

8.1 Security vs. Compatibility

Disabling TLS 1.0 / 1.1 impacts ≤2% of clients (IE11 on Windows 7, EOL since 2020). Accepted because the affected population runs unpatched software that presents greater ecosystem risk than the accessibility loss.

CSP unsafe-inline is required by the current page architecture. Planned migration to nonce-based CSP ('nonce-{random}') will address this without breaking inline functionality.

SSH port 22 is open to 0.0.0.0/0 alongside the team IP for lab operational flexibility. Explicitly documented as a known limitation — production requires bastion-only restriction.

8.2 Performance Considerations

Optimization	Detail	Outcome
DH Parameter Generation	4096-bit generation takes ~15 min on t4g.small — one-time cost	Logjam mitigation — security gain far outweighs the delay
TLS Session Cache	10 MB shared cache (~40,000 sessions)	Reduces handshake overhead on returning clients
ssl_session_tickets off	Prevents ticket-key reuse	Preserves PFS across session resumptions
HTTP/2	HPACK header compression and multiplexed requests	Reduces page load latency without security trade-offs
ChaCha20-Poly1305	Included for ARM64 Graviton2 — no AES-NI hardware	Outperforms AES-GCM in pure software on this platform

8.3 Testing & Troubleshooting

Issue	Root Cause	Resolution
unsupported dictionary type: hash	Rocky Linux 9/10 removed Berkeley DB	Migrated all hash: maps to lmdb:
DNSSEC — no ad flag	Oracle had not yet inserted DS record	Waited for Oracle; CAA + CT monitoring as interim controls

Issue	Root Cause	Resolution
DNSSEC — KMS permissions error	CMK policy missing Route 53 actions	Added route53.amazonaws.com as permitted principal
Certificate permission denied	/etc/letsencrypt root-owned only	ssl-cert group + chmod 750 + g+s sticky bit
Webmail showing castle page	gwallofchina.conf catching all traffic	Separate server_name per Nginx config file
Direct send rejected by Gmail (5.7.26 DMARC)	No DKIM signature on direct mail	Deployed OpenDKIM milter for local signing
OpenDKIM exit code 78 on startup	TrustAnchorFile path absent on Rocky Linux 10	Removed TrustAnchorFile from opendkim.conf
signing table references unknown key	KeyTable file was empty	Rewrote both SigningTable and KeyTable
CharacterStringTooLong — DKIM TXT	Full RSA key exceeds 255-char DNS TXT limit	Split key into multiple quoted chunks in single ResourceRecord
SPF fail on direct-sent mail	Two conflicting SPF records in DNS	Deleted v=spf1 -all record; kept correct record
Port 465 (SMTPS) not listening	smtps block missing from master.cf	Added smtps inet n - n - - smtpd block with smtpd_tls_wrappermode=yes
master.cf sed corruption	sed -i merged multi-line block to one line	Rewrote master.cf manually
MTA-STS — no certificate	Subdomain not in original SAN cert	Expanded cert with certbot --expand -d mta-sts.*
mydestination + virtual_mailbox_domains conflict	Domain listed in both directives	Removed $mydomain from mydestination
default._domainkey placeholder record live	Template value never replaced; origin unknown	Deleted from Route 53 — confirmed NXDOMAIN post-deletion
Doubled CAA record (domain.domain)	Full domain accidentally used as subdomain prefix during record creation	Deleted from Route 53 — confirmed NXDOMAIN post-deletion

11 FINAL DEPLOYMENT STATUS

Component	Status	Detail
Outbound SMTP — direct (primary)	**Working**	relayhost = empty · OpenDKIM signs · port 25 open
Outbound SMTP — SendGrid (fallback)	**Configured**	fallback_relay = [smtp.sendgrid.net]:587
Inbound SMTP — port 25	**Working**	MX → mail.gwallofchina.yulcyberhub.click:25
OpenDKIM DKIM signing	**Active**	s=mail · confirmed in mail logs
SPF	**Pass**	ip4:54.226.198.180 include:sendgrid.net mx ~all
DKIM	**Pass**	Direct: OpenDKIM mail._domainkey · Fallback: SendGrid s1/s2
DMARC	**Pass**	p=reject · adkim=s · aspf=s
MTA-STS	**Active**	mode: enforce · policy file live
Port 465 (SMTPS)	**Listening**	Implicit TLS
Port 587 (Submission)	**Listening**	STARTTLS
Port 993 (IMAPS)	**Listening**	Implicit TLS
Dovecot IMAP	**Working**	doveadm auth test confirmed
Webmail	**Live**	https://mail.gwallofchina.yulcyberhub.click
SSL certificate	**Valid**	Expires 2026-07-02 · SAN: main + mail + mta-sts
Certificate renewal	**Active**	authenticator = dns-route53 · no port 80 dependency
Auto-renewal timer	**Active**	certbot-renew.timer · twice daily
Deploy hook	**Configured**	Reloads nginx + postfix + dovecot on renewal
DNSSEC	**Validated**	ad flag confirmed · delv: fully validated
DNS zone — default._domainkey	**Deleted**	Placeholder record removed · NXDOMAIN confirmed
DNS zone — doubled CAA	**Deleted**	Misconfigured record removed · NXDOMAIN confirmed

12 REFERENCES

#	Author(s)	Title	Type	Year	URL
[1]	Mozilla Foundation	Mozilla SSL Configuration Generator	Tool	2024	https://ssl-config.mozilla.org
[2]	Qualys, Inc.	SSL Labs Server Test	Tool	2024	https://www.ssllabs.com/ssltest/
[3]	E. Rescorla	TLS Protocol Version 1.3 — RFC 8446	RFC	2018	https://datatracker.ietf.org/doc/html/rfc8446
[4]	K. Moriarty, S. Farrell	Deprecating TLS 1.0 and TLS 1.1 — RFC 8996	RFC	2021	https://datatracker.ietf.org/doc/html/rfc8996
[5]	M. Kucherawy, E. Zwicky	DMARC — RFC 7489	RFC	2015	https://datatracker.ietf.org/doc/html/rfc7489
[6]	D. Margolis et al.	MTA-STS — RFC 8461	RFC	2018	https://datatracker.ietf.org/doc/html/rfc8461
[7]	P. Hallam-Baker et al.	DNS CAA Resource Record — RFC 8659	RFC	2019	https://datatracker.ietf.org/doc/html/rfc8659
[8]	R. Arends et al.	DNS Security Introduction — RFC 4033	RFC	2005	https://datatracker.ietf.org/doc/html/rfc4033
[9]	Let's Encrypt	Let's Encrypt Documentation	Docs	2024	https://letsencrypt.org/docs/
[10]	EFF	Certbot Documentation	Docs	2024	https://certbot.eff.org/docs/
[11]	K. McKay et al.	NIST SP 800-52 Rev. 2 — TLS Guidelines	Standard	2019	https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final
[12]	D. Adrian et al.	Logjam Attack — weakdh.org	Research	2015	https://weakdh.org
[13]	B. Möller et al.	POODLE — SSL 3.0 Fallback	Research	2014	https://www.openssl.org/~bodo/ssl-poodle.pdf
[14]	T. Duong, J. Rizzo	BEAST Attack — CVE-2011-3389	Research	2011	https://nvd.nist.gov/vuln/detail/CVE-2011-3389
[15]	Chromium Project	HSTS Preload List Submission	Web	2024	https://hstspreload.org
[16]	W. Venema	Postfix TLS Support	Docs	2024	https://www.postfix.org/TLS_README.html

#	Author(s)	Title	Type	Year	URL
[17]	Dovecot	Dovecot SSL Configuration	Docs	2024	https://doc.dovecot.org/configuration_manual/dovecot_ssl_configuration/
[18]	Twilio SendGrid	DKIM Records	Docs	2024	https://docs.sendgrid.com/ui/account-and-settings/dkim-records
[19]	Amazon Web Services	Route 53 DNSSEC Configuration	Docs	2024	https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/dns-configuring-dnssec.html
[20]	Amazon Web Services	Key Policies in AWS KMS	Docs	2024	https://docs.aws.amazon.com/kms/latest/developerguide/key-policies.html
[21]	The OpenDKIM Project	OpenDKIM Documentation	Docs	2024	http://www.opendkim.org/docs.html
[22]	ByteNess	aws-vault	Tool	2024	https://github.com/ByteNess/aws-vault
[23]	Sandia National Laboratories	DNSViz DNSSEC Visualizer	Tool	2024	https://dnsviz.net
[24]	S. Roy	Project Scripts Repository	Code	2024	https://github.com/mrblue223/CyberSecurity_School_Labs/tree/main/Optimizing_SSL_Certificates/scripts
[25]	W. Venema	Postfix Virtual Mailbox Hosting	Docs	2024	https://www.postfix.org/VIRTUAL_README.html
[26]	IETF	MTA-STS Policy File Specification — RFC 8461	RFC	2018	https://datatracker.ietf.org/doc/html/rfc8461
[27]	Certbot	certbot-dns-route53 Plugin	Docs	2024	https://certbot-dns-route53.readthedocs.io
[28]	MXToolbox	Email Header Analyzer	Tool	2024	https://mxtoolbox.com/EmailHeaders.aspx
[29]	Port25 Solutions	Email Verifier (check-auth)	Tool	2024	https://www.port25.com/authentication-checker/
[30]	dmarcian	DMARC Inspector	Tool	2024	https://dmarcian.com/dmarc-inspector/
[31]	redsift	Email Tester	Tool	2026	https://redsift.com/tools/investigate